



OPEN SOURCE
SecurityCon

OSCAL in Action

Real World Examples of Automating
Policy & Compliance



OPEN SOURCE
SecurityCon

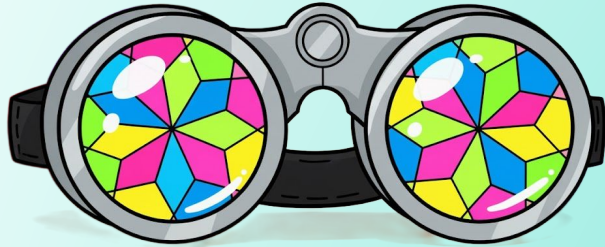


Jenn Power
Principal Product
Security Engineer
Red Hat



Hannah Braswell
Associate Product
Security Engineer
Red Hat

A Realistic Look at the *Now*



Lack of standardization in the compliance domain

- Data Silos & Ambiguity

Fragmented environment

- Difficult to achieve a clear, unified security posture

Preparedness for the *Later*



Continuously changing tech standards

- AI, Quantum, etc.

Evolving Regulations

- HIPAA Omnibus rules
- GDPR & EU CRA

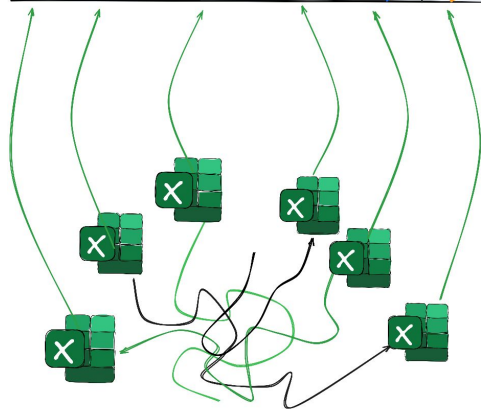
Define and follow your own **Security** and **Operational Policy**

- *Eliminate* internal ambiguity

Map your **internal policy** to **compliance requirements**

- Efficient & Defensible *later*

Req 1.0.0.a	evidence of compliance		
Req 1.0.0.b	evidence of compliance		
Req 1.0.0.c	evidence of compliance		
Req 1.0.0.d	evidence of compliance		
Req 1.0.0.e	evidence of compliance		
Req 1.0.0.f	evidence of compliance		



Evidence Collector

export 20241125T184900Zv

	A	B	C	D	E	F
1	A.B.1	Annex A > A.B. - Technological controls => A.B.1 - User and point devices	Information stored on, processed by or accessible via user end point devices shall be protected.	In progress		
2	A.B.2	Annex A > A.B. - Technological controls => A.B.2 - Privileged access rights	The allocation and use of privileged access rights shall be restricted and managed.	In progress		
3	A.B.3	Annex A > A.B. - Technological controls => A.B.3 - Information access restriction	Access to information and other associated assets shall be restricted in accordance with the established...	In progress		
4	A.B.4	Annex A > A.B. - Technological controls => A.B.4 - Access to source code	Read and write access to source code, development tools, and software libraries shall be...	In progress		
5	A.B.5	Annex A > A.B. - Technological controls => A.B.5 - Secure authentication	Secure authentication technologies and procedures shall...	In progress		
6	A.B.6	Annex A > A.B. - Technological controls => A.B.6 - Capacity management	Protection against malware shall be implemented and...	In progress		
7	A.B.7	Annex A > A.B. - Technological controls => A.B.7 - Protection against malware	Information about technical vulnerabilities of information...	In progress		
8						
9						
10						

Manual updates when regulations change



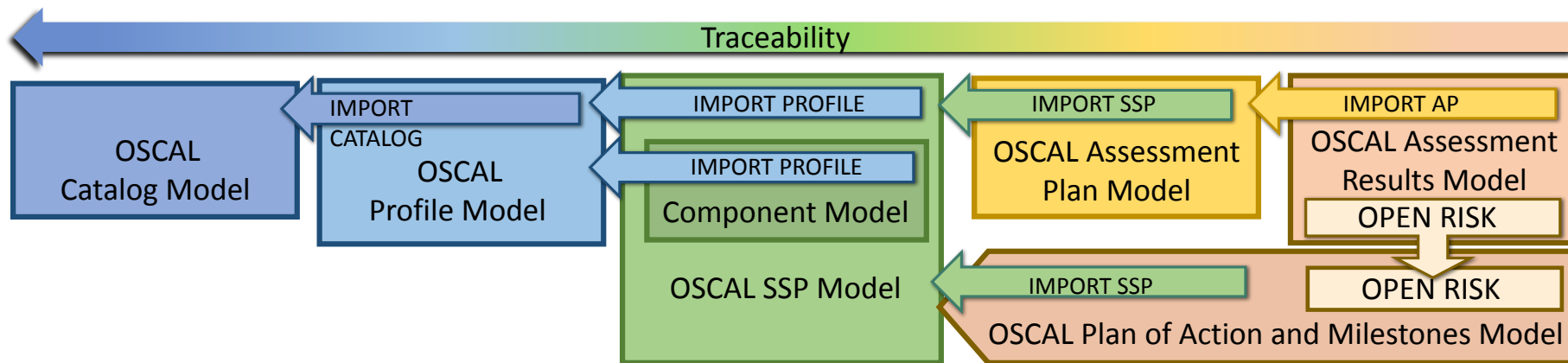
It **fails** the “Later” test because:

- **It's Slow**
 - Can't keep pace with **Cloud Native**
- **It's Ambiguous**
 - Inconsistencies and audit findings.
- **It's Audit-Focused**
 - *Paperwork*-focused for the **auditor**

What is OSCAL?

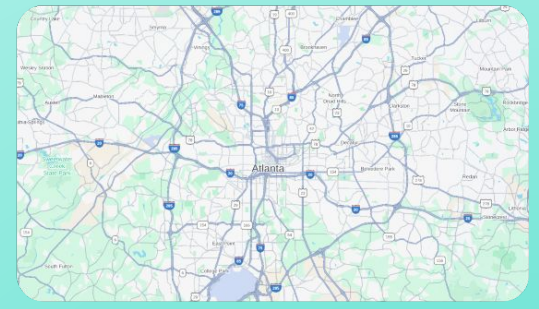
OSCAL is a **set of formats** expressed in **YAML**, **JSON**, and **XML**.

These formats provide **machine-readable** representations of control catalogs, control baselines, system security plans, and assessment plans and results.



Control Layer

OSCAL Control Source
(Catalog/Profile)



Implementation Layer

OSCAL Component
Definition

OSCAL System Security
Plan



Assessment Layer

OSCAL Assessment
Plan

OSCAL Assessment
Results





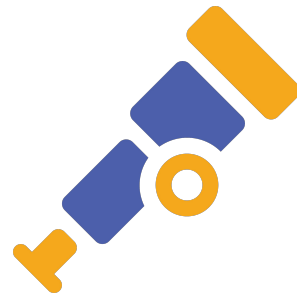
OSCAL Compass

The **compliance-to-policy** project translates compliance to low-level policy data



Open Policy Agent

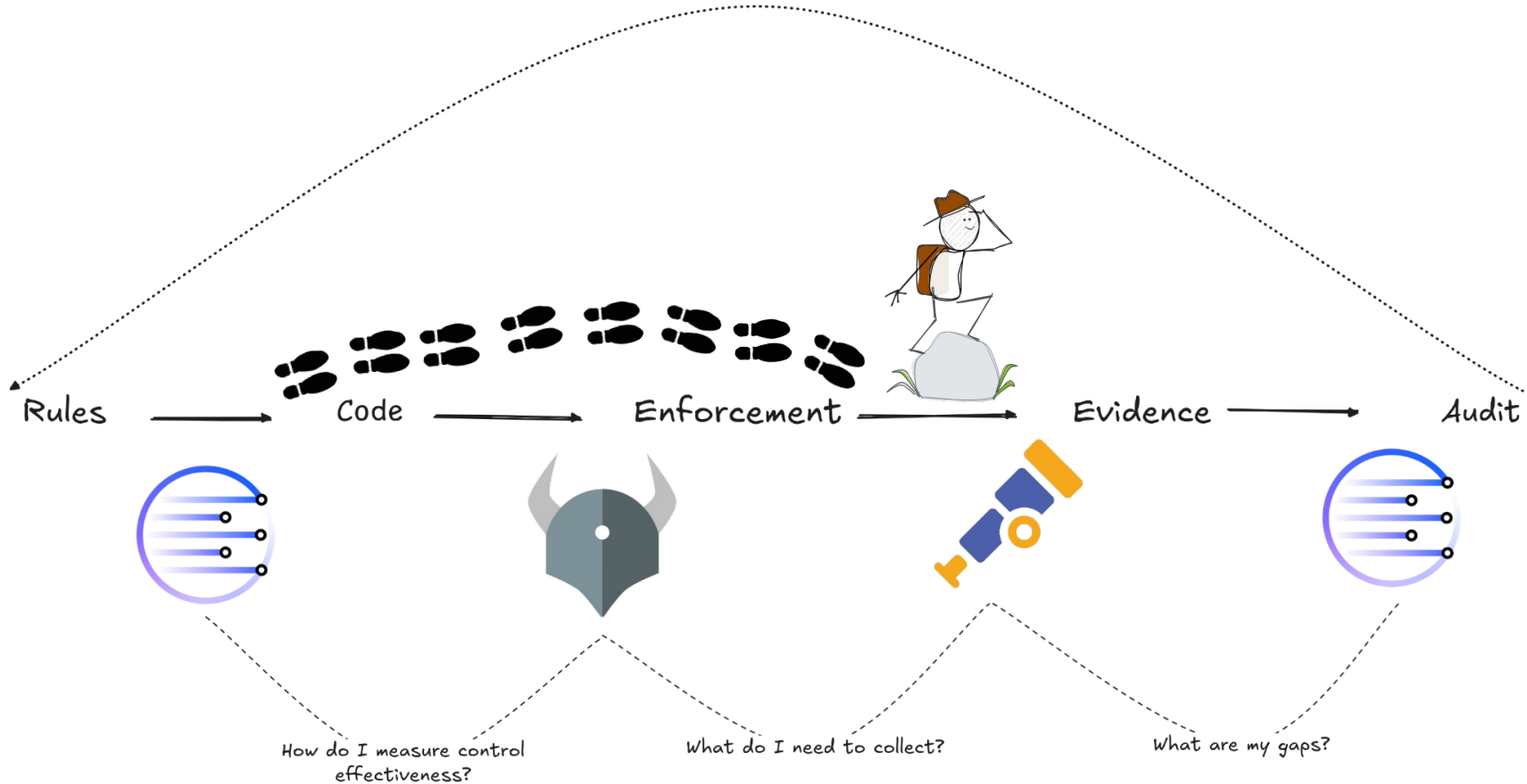
Enforces our policies across the application lifecycle - **conftest** or the **opa CLI** can help us in CI



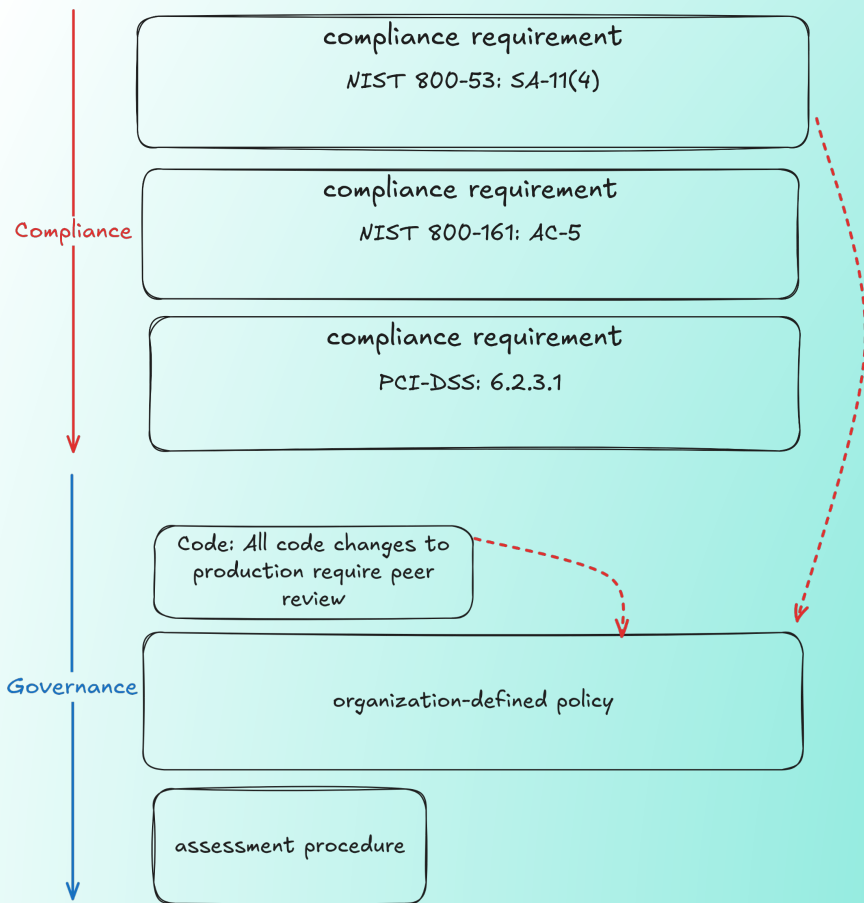
OpenTelemetry

The **collector** captures policy decisions and correlates to our compliance data

Defining a **Traceable** Path



An Organizational View



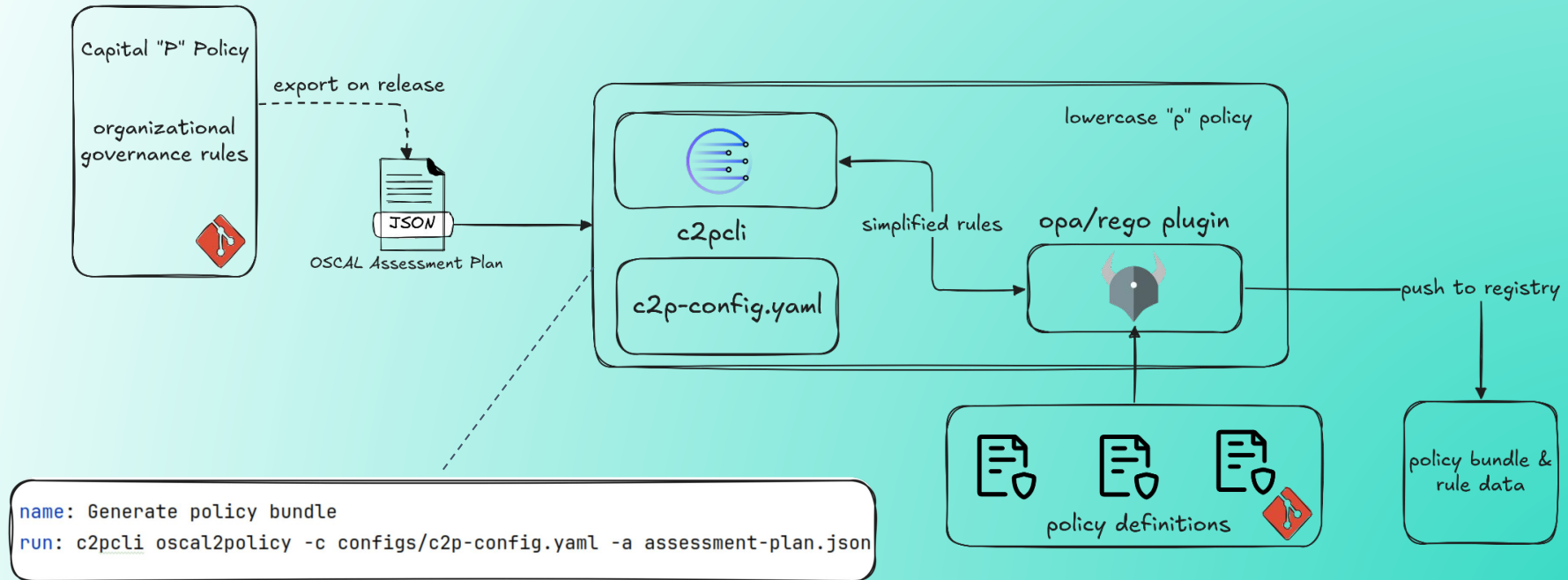
```
- id: CNSCC-SSC-09
title: Enforce Independent Review for Production Code Changes
objective: |
  Ensure a independent peer-review process is
  completed for all production code changes.
guideline-mappings:
  - reference-id: 800-53
    entries:
      - reference-id: SA-11(4)
        strength: 7
  - reference-id: 800-161
    entries:
      - reference-id: AC-5
        strength: 6
      - reference-id: SA-15
        strength: 7
  - reference-id: PCIDSS
    entries:
      - reference-id: 6.2.3.1
        strength: 8
assessment-requirements:
  - id: CNSCC-SSC-09.01
text: |
  All code destined for production must undergo a manual review.
  At least two reviewers with equal or greater expertise should
  review and approve the changes. The author(s) of the code may not
  also be the final approver of the associated merge/pull request.
applicability:
  - public
  - internal
  - confidential
  - restricted
recommendation: |
  Require independent peer review and approval via an automated
  Source Code Management (SCM) tool (e.g., Pull Request/Merge Request process).
```

Control satisfies these guidelines or requirements to varying degrees



Creating a **Policy** Bundle

Policy - Describes **rules** and what needs to be assessed in **natural language**
policy - **Operational logic** to evaluate structured input in **query language**



Inside the Policy Bundle



OPEN SOURCE
SecurityCon

OSCAL Assessment Plan

Rego Policy Definition

```
{
  "description": "The author(s) of a request may not also be the approver",
  "props": [
    {
      "name": "method",
      "value": "TEST"
    }
  ],
  "related-controls": {
    "control-selections": [
      {
        "include-controls": [
          {
            "control-id": "sa-11.4"
          }
        ]
      }
    ]
  },
  "steps": [
    {
      "description": "The procedure performs an automated check of GitHub",
      "title": "github_branch_protection",
      "uuid": "df03a965-edd3-4abe-843b-a76812e60149"
    }
  ],
  "title": "CNSCC-SSC-09.01",
  "uuid": "397cdedd-92db-4ac1-9c07-6ba87c57d456"
}
```

```
# METADATA
# title: GitHub Branch Protection Policy - Minimum Approvals
# description: >-
#   Enforces that at least one reviewer with equal or greater expertise
#   should review & approve the request. For projects with only two maintainers,
#   one reviewer is sufficient to ensure author-approver separation.
#   Verifies that the branch protection rule for the 'main' branch has at least 1 required approval.
# custom:
#   short_name: github_branch_protection

deny contains result if {
  has_pull_request_rule

  # Requires at least one reviewer with equal or greater expertise
  # For projects with only two maintainers, one reviewer ensures author-approver separation
  MINIMUM_REQUIRED_APPROVALS := 1

  some rule in input.values
  rule.type == "pull_request"
  rule.parameters.required_approving_review_count < MINIMUM_REQUIRED_APPROVALS

  chain := rego.metadata.chain()
  annotations := chain[0].annotations

  result := {
    "short_name": annotations.custom.short_name,
    "msg": sprintf("Violation: Branch protection requires at least %v reviewer with equal or greater expertise")
  }
}
```

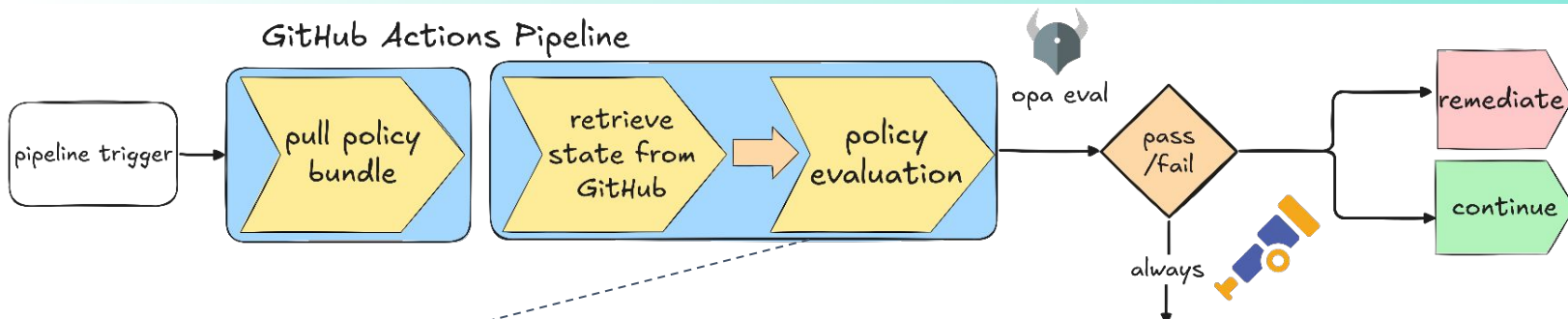
This value can also be set dynamically using external (rule) data

Short name is propagated to results when there is a violation

Code

The Enforcement Pipeline

GitHub Actions Pipeline

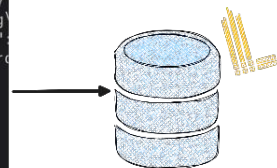


Branch protection rules **must** be defined for the primary branch

One branch protection rule **must** require pull requests to make changes to the primary branch

Pull requests **must** have 1 approval(s) before merge

```
timestamp: 2025-10-19 03:35:35.076 +0000 UTC
SeverityText: WARN
SeverityNumber: Warn(13)
Body: Str({"activity_id":0,"activity_name":"","category_name":"Application Activ
uid":6007,"cloud":{"provider":""},"event_day":0,"message":"Branch protection for
e configured minimum of 2.","metadata":{"log_provider":"conftest","product":{"nam
xporter","version":""},"num_files":1,"osint":null,"scan":{"type_id":0},"severity"
:2,"time":1760844935076,"type_name":"","type_uid":60070,"policy":{"data":{"msg
views but has less than the configured minimum of 2.\\","policy\\":\\"\\","level\\
in.deny\\","short_name\\":\\"github_branch_protection\\"},"uid":"github_branch_pr
Attributes:
-> policy.rule.id: Str(github_branch_protection)
-> policy.rule.name: Str(unknown_policy_name)
-> policy.engine.name: Str(conftest)
-> policy.evaluation.result: Str(Failed)
-> policy.evaluation.message: Str(Branch protection for 'main' requires pul
of 2.)
-> compliance.remediation.action: Str(Notify)
-> compliance.remediation.status: Str(Unknown)
-> compliance.status: Str(NON_COMPLIANT)
-> compliance.control.id: Str(CNSCC-SSC-09.01)
-> compliance.control.catalog.id: Str(CNSCC)
-> compliance.control.category: Str(Securing the Source Code)
-> compliance.requirements: Slice(["SA-11(4)"])
-> compliance.frameworks: Slice(["800-53"])
-> compliance.remediation.description: Str(https://docs.github.com/en/repos
/managing-protected-branches/managing-a-branch-protection-rule)
Trace ID: 86bf88d75445e9efbf197ef3cf910fe1
10-7-2025-10-19 03:35:35.076 +0000 UTC
```



Curating **Evidence** with OpenTelemetry

Deploy collector **alongside** the instrumented policy or assessment tool

```
receivers:  
  otlp:  
    protocols:  
      grpc:  
        endpoint: 0.0.0.0:4317  
      http:  
        endpoint: 0.0.0.0:4318
```

Collect from a wide variety of sources when events happen

Capture policy decisions and **correlate** them to compliance data

```
processors:  
  transform:  
    log_statements:  
      - context: log  
        statements:  
          - set(attributes["compliance.frameworks"], ["800-53"])  
          - set(attributes["compliance.status"], "NON_COMPLIANT") where attributes["policy.evaluation.result"] == "Failed"  
          - set(attributes["compliance.requirements"], ["SA-11(4)"]) where attributes["policy.rule.id"] == "github_branch_protection"
```

And send logs to **different backends** based on compliance rules

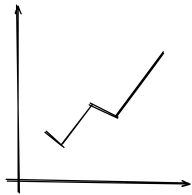
```
exporters:  
  debug:  
  awss3/logs:  
    s3uploader:  
      region: 'us-east-1'  
      s3_bucket: 'otel-data-backup'  
  otlphttp:  
    endpoint: "${env:OTLP_ENDPOINT}"
```

Example routing to Loki for real time analysis and S3 for long term storage

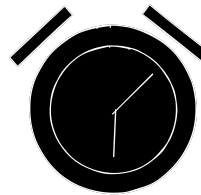
Continuous Monitoring



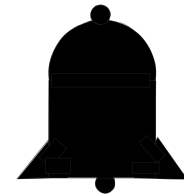
Develop Control Metrics



Define Thresholds

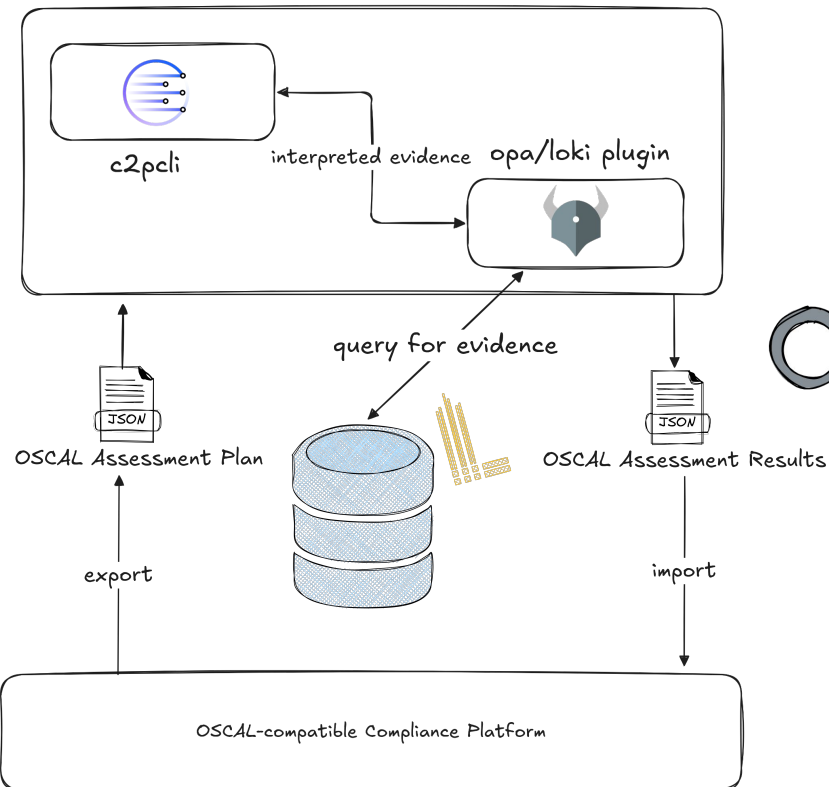


Configure Alerting



The Final **Audit** Artifact

Report Generation



OSCAL Assessment Results

```
"observations": [
  {
    "collected": "2025-10-13T18:58:52.335920211Z",
    "props": [
      {
        "name": "assessment-rule-id",
        "ns": "https://oscal-compass.github.io/compliance-trestle/schemas/oscal",
        "value": "CNSSC-SSC-09.01"
      },
      {
        "name": "assessment-check-id",
        "ns": "https://oscal-compass.github.io/compliance-trestle/schemas/oscal",
        "value": "github_branch_protection"
      }
    ]
  },
  "relevant-evidence": [
    {
      "description": "Evidence from Loki log entry at 1760378573044000000",
      "href": "https://logs.example.grafana.net/loki/api/v1/query_range?query={public"
    }
  ],
  "subjects": [
    {
      "props": [
        {
          "name": "result",
          "ns": "https://oscal-compass.github.io/compliance-trestle/schemas/osca",
          "value": "fail"
        }
      ]
    }
  ]
}
```

API query for reproducible retrieval

Interpreted result

Learn More



OPEN SOURCE
SecurityCon

Want to try this **yourself**?

Source code for workflow that provided the code snippets and a hands-on example are available in this repository



[opensource-securitycon-2025-oscal-in-action repo](#)

Where are we **implementing** *this* integration pattern?

We incorporate these components and use them as described in the ComplyTime project



[complytime github organization](#)

- ~~Manual Evidence Collection~~
- ~~Confined to Monolithic tools~~
- Leveraging existing stack of open source tools [c2p](#), [OPA](#), [OTEL](#) ✓
- Satisfying requirements beyond NIST ✓
- Reduced fragmentation and extensibility ✓

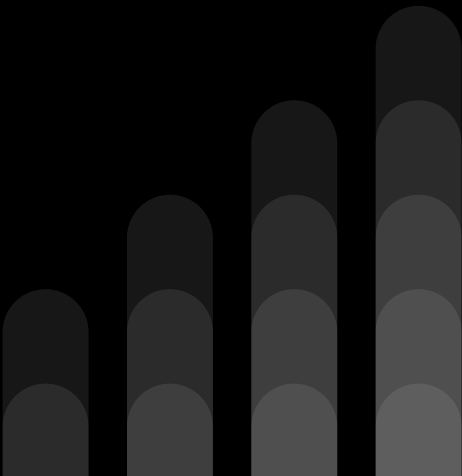


OPEN SOURCE
SecurityCon

Questions?



Appendix



Project Links:

- <https://github.com/usnistgov/OSCAL>
- <https://github.com/oscal-compass>
- <https://github.com/open-telemetry>
- <https://github.com/open-policy-agent>
- <https://github.com/ossf/gemara>

Presentation Resources:

Diagrams and drawings in this presentation were supported by Excalidraw and its libraries -

<https://github.com/excalidraw/excalidraw> (License: MIT)

A Closer Look at Governance

